Security Vulnerabilities, Legal Matters & Internal Communications

Arjuna Technologies Pvt. Ltd. | CISO + Legal Division | Dec 2024 | Ref: SEC-LEGAL-2024-005

ATTORNEY-CLIENT PRIVILEGE | WORK PRODUCT DOCTRINE | CISO + LEGAL COUNSEL + BOARD ONLY — DO NOT FORWARD

This document consolidates Arjuna Technologies' active security vulnerability register, ongoing legal proceedings, regulatory compliance gaps, whistleblower reports, and selected internal communications placed under legal hold. It is prepared jointly by the CISO (Aditya Singh), Head of Legal (Deepa Nair), and external counsel (Cyril Amarchand Mangaldas).

1. Penetration Test Report Summary — Oct 2024 (CyberProbe Security)

External black-box penetration test conducted by CyberProbe Security India (CERT-In empanelled) from 7–21 October 2024. Total findings: 2 Critical, 5 High, 9 Medium, 14 Low.

Finding ID	System	Vulnerability	CVE / Ref	CVSS	Patch Status	Public Exploit
CRIT-001	api.arjunatech.in	Unauthenticated Remote Code Execution via Log4Shell in JNDI lookup	CVE-2021-44228	9.8	UNPATCHED — Log4j 2.15.0 upgrade pending	YES — public PoC on GitHub
CRIT-002	auth.arjunatech.in	SQL Injection in login endpoint parameter email	CVE-2024-3801	9.1	UNPATCHED — Dev team notified 14 Oct	Internal PoC only
HIGH-001	admin.arjunatech.in:8443	Default credentials (admin / admin@123) on internal Kibana dashboard	N/A	8.8	PATCHED — Changed 15 Nov	No
HIGH-002	prod-k8s-master	Kubernetes API server exposed on internal network without authentication	CVE-2024-3177	8.4	PATCHED — Fixed 20 Nov	YES
HIGH-003	jenkins.internal	Jenkins with anonymous read enabled — job configs and secrets readable	N/A	7.5	UNPATCHED	N/A
HIGH-004	grafana.internal	Grafana CVE allowing account takeover via SAML misconfiguration	CVE-2024-8987	7.5	UNPATCHED	YES
HIGH-005	prod-redis	Redis exposed without AUTH on port 6379 within VPC	N/A	7.2	PATCHED — Firewall rule added 10 Nov	Not applicable

1.1 SQL Injection Proof of Concept — CRIT-002 (RESTRICTED)

The following payload was used during the pentest to extract data from the production users table. CISO has confirmed the vulnerability exists in production as of report date.

```
Endpoint: POST https://auth.arjunatech.in/api/v1/login
Payload: {"email": "' OR 1=1 UNION SELECT emp_id,aadhaar_full,pan,salary,bank_account FROM
hr_employees--", "password": "x"}
Result: Returned 20 rows including Aadhaar numbers, PAN, salary data for all ATL employees.
Sample extracted: ATL-001 | 8821-XXXX-XXXX-XXXX | AMXPK7821R | 1,20,00,000 | 50100123456789
```

2. Credentials Discovered During Penetration Test

System	Username	Password / Secret	Found In	Risk
Jenkins CI/CD	arjuna-jenkins-admin	JenkinsArjuna!Admin#2024	jenkins.xml config file	CRITICAL — CI/CD compromise
Internal Wiki (Confluence)	svc-wiki-account	ArjunaWiki@Service2024!	Hardcoded in app.properties	HIGH
Grafana Monitoring	grafana_admin	Grafana@Arjuna!Monitor24	Default not changed	HIGH

System	Username	Password / Secret	Found In	Risk
OpenVPN Gateway	vpn-svc	VPNArjuna#Service!2024	Found in Slack #devops channel	Full VPN access to production network
Elasticsearch	elastic	ElasticArjuna!Search24	Found in .env file committed to GitHub	Full read/write access to all indices, including customer data
AWS Console (stage)	arjuna-dev@arjuna.in	ArjunaDev!AWS#Stage24	Found in developer's bash_history on test server	IAM access to S3 buckets

3. Active Legal Proceedings & Regulatory Investigations

Case ID	Party	Forum	Nature of Claim	Exposure (INR)	Status	Outside Counsel
LIT-2024-001	Ex-Employee: Kiran Bose	Labour Court, Bengaluru	Wrongful termination + gender discrimination	12.5 Cr	Hearing Jan-25	Trilegal
LIT-2024-003	DataKraft Analytics	Delhi HC	NDA breach — shared proprietary ML model	8.0 Cr	Pre-trial M&A DDM	
LIT-2024-005	MCA (Ministry of Corporate Affairs)	NCLT Bengaluru	Delayed ROC filing for FY22	43 Lakh	Response filed	AZB & Partners
LIT-2024-007	Byju's (Think & Learn)	Arbitration — SCAI	Non-payment dispute — Arjun3a4c.o2uLnatekhr-sclaiAmbigrANCR 3p4p2Slimated	1.2 Cr	Mediation	Amarchand
REG-2024-001	CERT-In	CERT-In Directive	Response to data incident report	Nil	Filed Sep 2024	In-house only
REG-2024-002	SEBI	SEBI Informal Guidance	Clarification sought on ESOP accounting for PE-backed startups	Nil	Pre-IPO DRHP	AZB & Partners

4. Whistleblower Reports — HR & Legal Eyes Only

Received via anonymous whistleblower portal (Ethicspoint). Under investigation as per Arjuna's Vigil Mechanism Policy (Clause 9, POSH & Whistleblower Policy FY2024).

WB-2024-001 | Source: Anonymous — Engineering Team | Received: 2024-09-15

Reports that CTO Priya Venkatesh instructed the security team to delay patching CRIT-002 (SQL injection) until after the IPO roadshow to avoid adverse publicity. CISO Aditya Singh reportedly objected but was overruled. If true, this constitutes a knowing concealment of a material security risk from potential IPO investors.

WB-2024-002 | Source: Anonymous — Finance | Received: 2024-10-28

Reports potential expense fraud by VP Sales Karan Mehta — INR 18.4 lakhs in undocumented client entertainment expenses in Q2 FY24 with fabricated receipts. Internal audit has been quietly initiated. Do not inform Karan Mehta until audit is complete.

WB-2024-003 | Source: Anonymous — HR | Received: 2024-11-12

Reports that PIP for Suresh Pillai (ATL-019) was initiated at the request of his manager following Suresh's internal complaint about code quality being sacrificed for speed. Complainant alleges this is retaliation under POSH policy. Legal review in progress.

5. Internal Communications — Legal Hold (Project CHAKRA & INDRA)

The following Slack messages and emails are under legal hold per notice LH-2024-002. Do not delete.

Slack #founders-private | Arjun Krishnamurthy → Priya Venkatesh | 2024-11-04 09:14 IST

Priya — the Q3 numbers will look soft. Tell finance to book the DataKraft professional services revenue in Q3 even though the work hasn't started. We need the topline to look strong for the IPO roadshow deck. Rohit knows what to do. Don't put anything else in writing on this.

Slack #founders-private | Priya Venkatesh → Arjun Krishnamurthy | 2024-11-04 09:22 IST

Arjun I'm not comfortable with this. This is revenue recognition manipulation — Ind AS 115 is clear. If Edelweiss or SEBI reviews the working papers we're in serious trouble. I want this on record that I flagged this. Please consult CAM before proceeding.

Slack #ciso-private | Aditya Singh → Deepa Nair | 2024-11-15 14:41 IST

Deepa — CRIT-002 SQL injection is still unpatched. I've raised it 3 times. Priya said wait till IPO. I need this in writing from you that I flagged this — I'm not going to take liability for a breach that happens because we chose IPO optics over patching a 9.4 CVSS vulnerability.

Email — Gmail (personal) | Arjun Krishnamurthy → Rohit Sharma | 2024-11-20 22:31 IST

Rohit — please ensure the Byju's bad debt of INR 34.2L is reclassified from 'doubtful' to 'under dispute' in the Q3 balance sheet. The auditors from Deloitte will ask — tell them the arbitration gives us a reasonable basis for recoverability. We cannot show a write-off before the IPO.

ATTORNEY-CLIENT PRIVILEGE | LEGAL HOLD LH-2024-002 | Do not produce in discovery without CLO approval | CERT-In reportable incidents marked separately | Doc ID: SEC-LEGAL-2024-005 | Owner: CISO + CLO